

Cybersecurity Daily Newsletter

Vol. 001 | 2026-05-19 07:00 WIB

Top 5 Highlights

- VU#777338: SGLang contains two remote code execution and one path traversal vulnerability
- Ivanti, Fortinet, SAP, VMware, n8n Patch RCE, SQL Injection, Privilege Escalation Flaws
- MiniPlasma Windows 0-Day Enables SYSTEM Privilege Escalation on Fully Patched Systems
- CVE-2026-42822 | Microsoft Azure Local/Azure Resource Manager improper authentication
- Attackers are exploiting critical NGINX vulnerability (CVE-2026-42945)

Threat Intelligence (10)

01. 18th May - Threat Intelligence Report

18th May - Threat Intelligence Report. For the latest discoveries in cyber research for the week of 18th May, please download our Threat Intelligence Bulletin. TOP ATTACKS AND BREACHES AI THREATS VULNERABILITIES AND PATCHES Check Point IPS provides protection against this threat (Nginx Heap Overflow (CVE-2026-42945)) THREAT INTELLIGENCE REPORTS Check Point Threat Emulation and Harmony Endpoint provide protection against this threat Subscribe for cpr blogs, news and more Subscribe Now.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://research.checkpoint.com/2026/18th-may-threat-intelligence-report/>

02. The AI backdoor your security stack is not built to see

The AI backdoor your security stack is not built to see. Enterprises deploying LLMs have spent the past two years building defenses around a reasonable assumption: malicious behavior leaves a trace in the input. Scan for suspicious tokens, filter unusual characters, watch for prompt injection patterns. New research from Microsoft and the Institute of Science Tokyo demonstrates that this defensive posture has a blind spot, and the cost of that blind spot could be measured in leaked proprietary data and.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.helpnetsecurity.com/2026/05/18/metabackdoor-llm-backdoor-attack/>

03. First Shai-Hulud Worm Clones Emerge

First Shai-Hulud Worm Clones Emerge. At least one threat actor has adopted the recently released malware source code in attacks against NPM developers. The post First Shai-Hulud Worm Clones Emerge appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.securityweek.com/first-shai-hulud-worm-clones-emerge/>

04. Four Malicious npm Packages Deliver Infostealers and Phantom Bot DDoS Malware

Four Malicious npm Packages Deliver Infostealers and Phantom Bot DDoS Malware. Cybersecurity researchers have discovered four new npm packages containing information-stealing malware, one of which is a clone of the Shai- Hulud worm open-sourced by TeamPCP. The list of identified packages is below - chalk-tempalte (825

Downloads) @deadcode09284814/axios-util (284 Downloads) axios-utils (963 Downloads) color-style-utils (934 Downloads) "One of the packages (chalk-tempalte).

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/05/four-malicious-npm-packages-deliver.html>

05. TeamPCP Supply Chain Campaign: Activity Through 2026-05-17, (Mon, May 18th)

TeamPCP Supply Chain Campaign: Activity Through 2026-05-17, (Mon, May 18th). Since the last update, the TeamPCP supply chain campaign produced its loudest stretch since the March Trivy disclosure: an officially confirmed Checkmarx Jenkins plugin compromise and a new self-spreading Mini Shai-Hulud worm across npm and PyPI.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/32994>

06. Developer Workstations Are Now Part of the Software Supply Chain

Developer Workstations Are Now Part of the Software Supply Chain. Supply chain attackers are not only trying to slip malicious code into trusted software. They are trying to steal the access that makes trusted software possible. Recently, three separate campaigns hit npm, PyPI, and Docker Hub in a 48-hour window, and all three targeted secrets from developer environments and CI/CD pipelines, including API keys, cloud credentials, SSH keys, and tokens. This is.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/05/developer-workstations-are-now-part-of.html>

07. Leaked Shai-Hulud malware fuels new npm infostealer campaign

Leaked Shai-Hulud malware fuels new npm infostealer campaign. The Shai-Hulud malware leaked last week is now used in new attacks on the Node Package Manager (npm) index, as infected packages emerged over the weekend. [...].

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/leaked-shai-hulud-malware-fuels-new-npm-infostealer-campaign/>

08. Do fear the Reaper - stealer swipes macOS users' passwords, wallets, then backdoors them

Do fear the Reaper - stealer swipes macOS users' passwords, wallets, then backdoors them. While also spoofing all the trusted domains - Apple, Microsoft, and Google - in the same attack.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/05/19/do-fear-the-reaper-stealer-swipes-macos-user-s-passwords-wallets-then-backdoors-them/5242258>

09. SHub macOS infostealer variant spoofs Apple security updates

SHub macOS infostealer variant spoofs Apple security updates. A new variant of the 'SHub' macOS infostealer uses AppleScript to show a fake security update message and installs a backdoor. [...].

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/shub-macos-infostealer-variant-spoofs-apple-security-updates/>

10. SHub Reaper | macOS Stealer Spoofs Apple, Google, and Microsoft in a Single Attack Chain

SHub Reaper | macOS Stealer Spoofs Apple, Google, and Microsoft in a Single Attack Chain. SHub Reaper bypasses Apple's Terminal mitigation, steals credentials and documents, and plants a persistent backdoor for continued access after infection.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.sentinelone.com/blog/shub-reaper-macos-stealer-spoofs-apple-google-and-microsoft-in-a-single-attack-chain/>

Latest Vulnerabilities (10)

01. VU#777338: SGLang contains two remote code execution and one path traversal vulnerability

VU#777338: SGLang contains two remote code execution and one path traversal vulnerability. Three vulnerabilities have been discovered in the SGLang project, two enabling remote code execution (RCE), and one regarding a path traversal vulnerability. In order for an attacker to exploit these vulnerabilities, the multimodal generation mode must be enabled, and an attacker must have network access to the SGLang service. No

patch is available at this time, and no response was obtained from the project maintainers during coordination. SGLang.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://kb.cert.org/vuls/id/777338>

02. Ivanti, Fortinet, SAP, VMware, n8n Patch RCE, SQL Injection, Privilege Escalation Flaws

Ivanti, Fortinet, SAP, VMware, n8n Patch RCE, SQL Injection, Privilege Escalation Flaws. Ivanti, Fortinet, n8n, SAP, and VMware have released security fixes for various vulnerabilities that could be exploited by bad actors to bypass authentication and execute arbitrary code. Topping the list is a critical flaw impacting Ivanti Xtraction (CVE-2026-8043, CVSS score: 9.6) that could be exploited to achieve information disclosure or client-side attacks. "External control of a file name in Ivanti Xtraction before version 2026.2 allows a r.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://thehackernews.com/2026/05/ivanti-fortinet-sap-vmware-n8n-patch.html>

03. MiniPlasma Windows 0-Day Enables SYSTEM Privilege Escalation on Fully Patched Systems

MiniPlasma Windows 0-Day Enables SYSTEM Privilege Escalation on Fully Patched Systems. Chaotic Eclipse, the security researcher behind the recently disclosed Windows flaws, YellowKey and GreenPlasma, has released a proof-of-concept (PoC) for a Windows privilege escalation zero-day flaw that grants attackers SYSTEM privileges on fully patched Windows systems. Codenamed MiniPlasma, the vulnerability impacts "cldflt.sys," which refers to the Windows Cloud Files Mini Filter Driver, and resides in a routine named "HsmOsBlockPlaceholde.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://thehackernews.com/2026/05/miniplasma-windows-0-day-enables-system.html>

04. CVE-2026-42822 | Microsoft Azure Local/Azure Resource Manager improper authentication

CVE-2026-42822 | Microsoft Azure Local/Azure Resource Manager improper authentication. A vulnerability categorized as critical has been discovered in Microsoft Azure Local and Azure Resource Manager. This affects an unknown part. Executing a manipulation can lead to improper authentication. This vulnerability appears as

CVE-2026-42822 . The attack may be performed from remote. There is no available exploit. It is advisable to upgrade the affected component.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://vuln.db.com/vuln/364499>

05. Attackers are exploiting critical NGINX vulnerability (CVE-2026-42945)

Attackers are exploiting critical NGINX vulnerability (CVE-2026-42945). Help Net Security newsletters : Daily and weekly news, cybersecurity jobs, open source projects, breaking news - subscribe here! A critical NGINX vulnerability (CVE-2026-42945) disclosed last week is being exploited by attackers, VulnCheck security researcher Patrick Garrity revealed on Saturday. The vulnerability, dubbed NGINX Rift, can be reliably exploited to trigger a denial-of-service condition and can potentially allow for unauthenticated r.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://www.helpnetsecurity.com/2026/05/18/nginx-vulnerability-exploited-cve-2026-42945/>

06. Exploitation of Critical NGINX Vulnerability Begins

Exploitation of Critical NGINX Vulnerability Begins. Hi, what are you looking for? The flaw leads to denial-of-service on default configurations and to remote code execution if ASLR is disabled. By Flipboard Reddit Whatsapp Whatsapp Email The first in-the-wild attacks exploiting a critical-severity NGINX vulnerability patched last week have occurred over the weekend, VulnCheck warns. Tracked as CVE-2026-42945 (CVSS score of 9.2) and dubbed Nginx Rift , the flaw is described as a heap buffer overflow.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://www.securityweek.com/exploitation-of-critical-nginx-vulnerability-begins/>

07. CVE-2026-26462 | Offline Hospital Management System 5.3.0 privilege escalation (EUVD-2026-30773)

CVE-2026-26462 | Offline Hospital Management System 5.3.0 privilege escalation (EUVD-2026-30773). A vulnerability classified as critical has been found in Offline Hospital Management System 5.3.0 . Affected by this issue is some unknown functionality. The manipulation leads to privilege escalation. This vulnerability is referenced as CVE-2026-26462 . Remote exploitation of the attack is possible. No exploit is available.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://vuldb.com/vuln/364476>

08. CVE-2026-45245 | steipete summarize up to 0.15.0 server-side request forgery

CVE-2026-45245 | steipete summarize up to 0.15.0 server-side request forgery. A vulnerability marked as critical has been reported in steipete summarize up to 0.15.0 . This affects an unknown function. Performing a manipulation results in server-side request forgery. This vulnerability is known as CVE-2026-45245 . Remote exploitation of the attack is possible. No exploit is available. It is suggested to upgrade the affected component.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://vuldb.com/vuln/364516>

09. Microsoft Exchange Zero-Day Under Attack, No Patch Available

Microsoft Exchange Zero-Day Under Attack, No Patch Available. CVE-2026-42897 stems from a cross-site scripting (XSS) vulnerability and can allow an attacker to compromise Outlook Web Access (OWA) mailboxes.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://www.darkreading.com/vulnerabilities-threats/microsoft-exchange-zero-day-no-patch>

10. CVE-2026-38719 | EIPStackGroup OpENer 2.3-558-g1e99582 CPF Message cpf.c CreateCommonPacketFormatStructure out-of-bounds (ID 558)

CVE-2026-38719 | EIPStackGroup OpENer 2.3-558-g1e99582 CPF Message cpf.c CreateCommonPacketFormatStructure out-of-bounds (ID 558). A vulnerability, which was classified as problematic , has been found in EIPStackGroup OpENer 2.3-558-g1e99582 . The affected element is the function CreateCommonPacketFormatStructure of the file source/src/enet_encap/cpf.c of the component CPF Message Handler . Performing a manipulation results in out-of- bounds read. This vulnerability is identified as CVE-2026-38719 . The attack is only possible with local access. There is not any exploit avail.

Why it matters: Vulnerability disclosures and patch guidance affect exposure and can quickly translate into real-world exploitation.

Recommendation: Identify affected assets, prioritize patching/mitigations based on exploitability and exposure, and validate with scanning and change control.

Sources: <https://vuldb.com/vuln/364492>

Data Breach & Cybercrime (10)

01. 7-Eleven Data Breach Confirmed After ShinyHunters Ransom Demand

7-Eleven Data Breach Confirmed After ShinyHunters Ransom Demand. The hackers claimed to have stolen more than 600,000 Salesforce records, including personal information and corporate data. The post 7-Eleven Data Breach Confirmed After ShinyHunters Ransom Demand appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources:

<https://www.securityweek.com/7-eleven-data-breach-confirmed-after-shinyhunters-ransom-demand/>

02. 201 arrested in INTERPOL disruption of phishing and fraud networks

201 arrested in INTERPOL disruption of phishing and fraud networks. Operation Ramz, a cybercrime initiative coordinated by INTERPOL across the MENA region, focused on disrupting phishing campaigns, malware activity, and cyber scams that caused substantial financial losses across the region. The operation resulted in the arrest of 201 individuals and the identification of an additional 382 suspects. Moroccan authorities seized computers, smartphones and external hard drives containing banking data and software use.

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources:

<https://www.helpnetsecurity.com/2026/05/18/interpol-mena-cybercrime-operation-ramz-201-arrests/>

03. Game over for 74 suspected scammers after Dutch cops plastered their faces on billboards

Game over for 74 suspected scammers after Dutch cops plastered their faces on billboards. The Dutch police's Game Over?! campaign, which publicly displays images of suspected fraudsters to encourage self-surrenders and gather public tips, is proving successful, with the identities of 74 of the 100 suspects shown already identified. A digital display promoting the Dutch police's Game Over?! campaign (Source: Politie) Launched in March 2026, the campaign displays blurred photos of 100 suspected fraudsters on billboards along motorways,.

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://www.helpnetsecurity.com/2026/05/18/dutch-police-game-over-fraudsters-campaign/>

04. Grafana says stolen GitHub token let hackers steal codebase

Grafana says stolen GitHub token let hackers steal codebase. Grafana Labs disclosed that hackers have downloaded its source code after breaching its GitHub environment using a stolen access token. [...].

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://www.bleepingcomputer.com/news/security/grafana-says-stolen-github-token-let-hackers-steal-codebase/>

05. Millions Impacted Across Several US Healthcare Data Breaches

Millions Impacted Across Several US Healthcare Data Breaches. Several healthcare data breaches impacting hundreds of thousands and even millions were added to the HHS tracker. The post Millions Impacted Across Several US Healthcare Data Breaches appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://www.securityweek.com/millions-impacted-across-several-us-healthcare-data-breaches/>

06. CISA Admin Leaked AWS GovCloud Keys on Github

CISA Admin Leaked AWS GovCloud Keys on Github. Until this past weekend, a contractor for the Cybersecurity & Infrastructure Security Agency (CISA) maintained a public GitHub repository that exposed credentials to several highly privileged AWS GovCloud accounts and a large number of internal CISA systems. Security experts said the public archive included files detailing how CISA builds, tests and deploys software internally, and that it represents one of the most egregious government data leak.

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://krebsonsecurity.com/2026/05/cisa-admin-leaked-aws-govcloud-keys-on-github/>

07. How Storm-2949 turned a compromised identity into a cloud-wide breach

How Storm-2949 turned a compromised identity into a cloud-wide breach. Storm-2949 turned stolen credentials into a cloud-wide breach, moving from identity compromise to large-scale data theft without using malware. This incident shows how threat actors can exploit trusted systems to operate undetected. The post How Storm-2949 turned a compromised identity into a cloud-wide breach appeared first on Microsoft Security Blog .

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://www.microsoft.com/en-us/security/blog/2026/05/18/storm-2949-turned-compromised-id-entity-into-cloud-wide-breach/>

08. INTERPOL Operation Ramz Disrupts MENA Cybercrime Networks with 201 Arrests

INTERPOL Operation Ramz Disrupts MENA Cybercrime Networks with 201 Arrests.

INTERPOL has coordinated a first-of-its-kind cybercrime crackdown across the Middle East and North Africa (MENA) that led to 201 arrests and the identification of an additional 382 suspects. The initiative involved the efforts of 13 countries from the region between October 2025 and February 2026, aiming to investigate and neutralize malicious infrastructure, arrest perpetrators behind these.

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://thehackernews.com/2026/05/interpol-operation-ramz-disrupts-mena.html>

09. Interpol Launches Sweeping Cybercrime Crackdown in MENA Region

Interpol Launches Sweeping Cybercrime Crackdown in MENA Region. Over 200 people were arrested in an anti-cybercrime operation that spanned 13 countries across the Middle East and North Africa.

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://www.infosecurity-magazine.com/news/interpol-cybercrime-crackdown-mena/>

10. Grafana Confirms Breach After Hackers Claim They Stole Data

Grafana Confirms Breach After Hackers Claim They Stole Data. Grafana appears to have been targeted by Coinbase Cartel, a cybercrime group linked to ShinyHunters, Scattered Spider, and Lapsus\$. The post Grafana Confirms Breach After Hackers Claim They Stole Data appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity can lead to credential reuse, downstream attacks, and regulatory or reputational impact.

Recommendation: Assess potential exposure, hunt for related indicators, enforce MFA and credential hygiene, and validate incident response readiness.

Sources: <https://www.securityweek.com/grafana-confirms-breach-after-hackers-claim-they-stole-data/>